

Enhanced Attack Report

Small Sieve

Generated on 2025-10-08

Disclaimer

This report has been generated automatically and should be used for informational purposes only. To generate this report, Large Language Models (LLMs) were used to analyze the provided data. This technology is not perfect and may generate incorrect or misleading results. The results should be reviewed by a human expert before taking any action based on the information provided.

Definitions

Pre-Conditions: Conditions that must be true to execute the attack steps in the milestone.

Post-Conditions: Traces that an attacker leaves behind after executing the attack steps in the milestone.

Attack Steps: Steps that an attacker would take to achieve the goal of the milestone.

MITRE Technique: Techniques from the MITRE ATT&CK; framework that are relevant to the milestone.

STIX

Malware Name: Small Sieve

Malware Description: Small Sieve is a simple – possibly disposable – Python backdoor which is distributed using an NSIS installer that performs persistence. It provides basic functionality required to maintain and expand a foothold in victim infrastructure using custom string and traffic obfuscation schemes together with the Telegram Bot API to avoid detection.

Quick Overview

Milestone m1

a1. Command and Scripting Interpreter: Python as used by the malware (T1059.006)

Milestone m2

a2. Boot or Logon Autostart Execution: Registry Run Keys / Startup Folder as used by the malware (T1547.009)

Milestone m3

a3. Obfuscated Files or Information as used by the malware (T1027.013)

a4. Execution Guardrails as used by the malware (T1574.007)

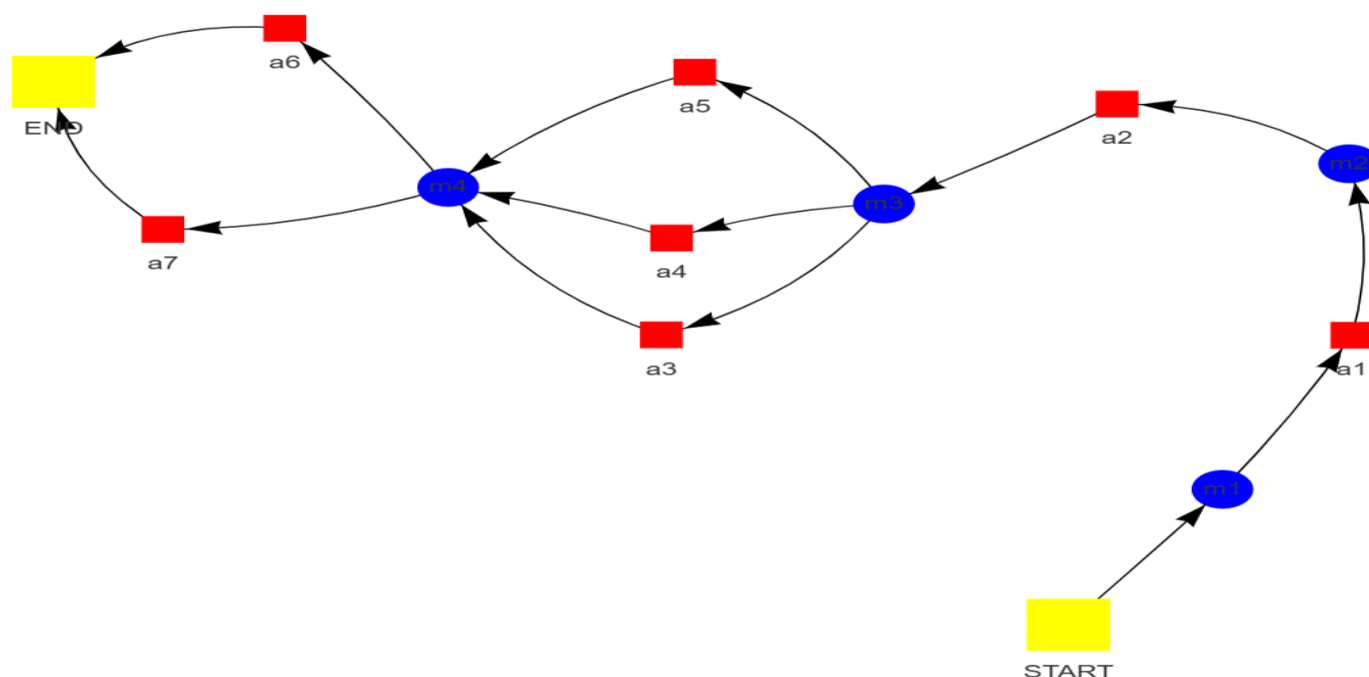
a5. Masquerading: Match Legitimate Name or Location as used by the malware (T1036.005)

Milestone m4

a6. Application Layer Protocol: Web Protocols as used by the malware (T1071.001)

a7. Data Encoding: Non-Standard Encoding as used by the malware (T1001.001)

Attack Graph



Milestone *m1*

Attack Step *a1*

=====

Name: Command and Scripting Interpreter: Python as used by the malware

Description: The Small Sieve backdoor, attributed to the Iranian advanced persistent threat (APT) group MuddyWater, is designed to facilitate persistent access to victim systems. Communication with the command-and-control (C2) infrastructure is established via Telegram's Bot API, potentially evading detection by conventional security measures. String obfuscation techniques are employed to render code strings unreadable and analysis challenging. The presence of a "Platypus" keyword check on the command line suggests a mechanism intended to prevent unauthorized execution or analysis. Small Sieve supports a range of commands for controlling infected systems, including termination of the backdoor connection, token updates, and disconnection from Telegram. MuddyWater's tactics associated with Small Sieve include spearphishing campaigns delivering malicious files, exploitation of known vulnerabilities, and the implementation of persistence mechanisms such as side-loading DLLs and obfuscated scripts. Organizations are advised to implement mitigation strategies such as software patching, multi-factor authentication (MFA), security awareness training, endpoint detection and response (EDR) solutions, and continuous network monitoring to protect against threats posed by Small Sieve and similar backdoors.

Pre-Conditions:

- The malware has access to the Python interpreter.
- A Python interpreter is available on the system.

Post-Conditions:

- Modified or deleted system files related to security software or logging.
- Obfuscated communication logs containing encoded data.
- Potential for further malicious activity on the compromised system.
- Presence of PowerShell scripts and VBS files used for execution.
- Data exfiltration to MuddyWater C2 servers.
- "OutlookMicrosift" Run key entry pointing to Small Sieve.
- Small Sieve binary ("index.exe") present in %LocalAppData% directory.
- New user account created (if applicable).
- Compromised system with persistent backdoor access.
- Modified registry keys related to persistence and execution of Small Sieve.

MITRE Technique

ID: T1059.006

Name: Command and scripting interpreter: python

Description: Adversaries may abuse Python commands and scripts for execution. Python is a very popular scripting/programming language, with capabilities to perform many functions. Python can be executed interactively from the command-line (via the python.exe interpreter) or via scripts (.py) that can be written and distributed to different systems. Python code can also be compiled into binary executables.

More info: <https://attack.mitre.org/techniques/T1059/006>

Milestone *m2*

Attack Step a2

=====

Name: Boot or Logon Autostart Execution: Registry Run Keys / Startup Folder as used by the malware

Description: A detailed analysis of MuddyWater's tactics, techniques, and procedures (TTPs) is provided herein. The document elucidates various facets of their operations, encompassing: Malware: * Small Sieve: A modular backdoor disseminated via an NSIS installer disguised as legitimate software. XOR encryption is employed for communication, and custom encoding schemes are utilized. * Canopy/Starwhale: Malware delivered through spearphishing emails containing targeted attachments. Windows Script Files (.wsf) are leveraged to execute malicious code. Infection Techniques: * Spearphishing: Targeted email campaigns delivering malicious attachments or links are conducted. * Exploit Kits: Potential exploitation of software vulnerabilities for initial access is indicated. Command and Control (C2): Multiple C2 infrastructures are utilized by MuddyWater for diverse purposes, including data exfiltration and command execution. Lateral Movement: The utilization of PowerShell backdoors for lateral movement within compromised networks is documented. Data Exfiltration: Collected data from victim systems is transmitted to adversary-controlled servers. Persistence: Various techniques are employed by MuddyWater to maintain persistent access, including registry run keys and startup folder entries. Defense Evasion: Obfuscation of malicious code and the utilization of legitimate filenames and registry keys to evade detection are observed. Key Takeaways: MuddyWater is characterized as a sophisticated APT group with a focus on espionage and data theft. Advanced techniques are employed for malware development, delivery, and evasion. Organizations are advised to be cognizant of the threats posed by MuddyWater and implement robust security measures to mitigate associated risks.

Pre-Conditions:

- The malware has the capability to access the startup folder.
- The malware has the capability to write to the registry.

Post-Conditions:

- Compromised systems with persistent backdoors.
- Unusual process activity and memory dumps.
- Obfuscated scripts and configuration files used by the malware.
- Altered registry entries indicating malicious activity.
- Potential for further malware infections and lateral movement within the network.
- Disruption of critical business operations.
- Files containing stolen data transferred to external servers.
- Loss of sensitive information and intellectual property.
- Reputational damage and loss of trust.
- New user accounts created with elevated privileges.
- Network traffic logs showing communication with adversary-controlled IPs.
- Data exfiltration to adversary-controlled servers.

MITRE Technique

ID: T1547.009

Name: Boot or logon autostart execution: shortcut modification

Description: Adversaries may create or modify shortcuts that can execute a program during system boot or user login. Shortcuts or symbolic links are used to reference other files or programs that will be opened or executed when the shortcut is clicked or executed by a system startup process.

More info: <https://attack.mitre.org/techniques/T1547/009>

Milestone *m3*

Attack Step *a3*

=====

Name: Obfuscated Files or Information as used by the malware

Description: Small Sieve, an advanced malware attributed to the Iranian APT group MuddyWater, is disseminated via an NSIS installer file designated "gram_app.exe". Upon installation, a backdoor binary named "index.exe" is deployed within the user's AppData/Roaming directory and registered as a Run key in the Windows registry, ensuring persistence across system reboots. Communication between Small Sieve and its command-and-control (C2) server is facilitated through the Telegram Bot API, leveraging HTTPS encryption for secure transmission. Further obfuscation of tasking and response data is achieved through a custom hex byte swapping algorithm and base64 encoding techniques. Small Sieve exhibits basic backdoor functionalities, enabling attackers to execute commands on infected systems, download files from remote servers, and upload files from the compromised system to the C2 server. A set of custom commands is also supported for specific actions, such as modifying the Telegram Bot API token or terminating the connection. Detection and mitigation efforts may involve file name analysis, focusing on unusual designations like "gram_app.exe" and "index.exe". Registry monitoring for suspicious entries related to Small Sieve's persistence mechanism is recommended. Network traffic analysis should scrutinize communication patterns with Telegram servers, particularly those exhibiting heavily obfuscated data.

Pre-Conditions:

- Access to the target files or information.
- The malware is present in the system.
- The attacker has access to the files or information they wish to obfuscate.
- The malware's code contains the functionality to obfuscate files or information.

Post-Conditions:

- Modified system files or configurations.
- Obfuscated strings in index.pyc file.
- Persistence registry key pointing to index.exe.
- Potential for further malicious activity on the compromised system.
- Data exfiltration to adversary-controlled infrastructure.
- Telegram session data.
- Logs indicating suspicious activity and command execution.
- Compromised system with persistent backdoor access.
- Presence of Small Sieve binary (%AppData%\OutlookMicrosift\index.exe).

MITRE Technique

ID: T1027.013

Name: Obfuscated files or information: encrypted/encoded file

Description: Adversaries may encrypt or encode files to obfuscate strings, bytes, and other specific patterns to impede detection. Encrypting and/or encoding file content aims to conceal malicious artifacts within a file used in an intrusion. Many other techniques, such as Software Packing, Steganography, and Embedded Payloads, share this same broad objective. Encrypting and/or encoding files could lead to a lapse in detection of static signatures, only for this malicious content to be

revealed (i.e., Deobfuscate/Decode Files or Information) at the time of execution/use.

More info: <https://attack.mitre.org/techniques/T1027/013>

Attack Step a4

=====

Name: Execution Guardrails as used by the malware

Description: A novel Python-based malware designated "Small Sieve" has been subjected to detailed analysis. The malware is characterized by its packaging with PyInstaller and exhibits attributes suggestive of association with the Iranian advanced persistent threat (APT) group MuddyWater, also known by aliases such as Earth Vetala, MERCURY, Static Kitten, Seedworm, and TEMP.Zagros. Small Sieve demonstrates capabilities including persistence through the addition of itself to the Windows registry for automatic execution upon system startup. Command and control functionality is facilitated via the Telegram Bot API, enabling communication with operators. Data exfiltration capabilities encompass the retrieval of system-related information such as IP address and logged-in user details. The malware's payload execution is contingent upon the presence of the string "Platypus" on the command line, serving as a rudimentary safeguard against unintended or unauthorized activation. Communication protocols employed by Small Sieve involve the Telegram Bot API, with messages encrypted and obfuscated through a custom hex byte shuffling algorithm. Detection and mitigation strategies emphasize the importance of monitoring system logs for anomalous activities, including novel registry entries or unusual network traffic directed towards Telegram servers. Security tools are recommended to be updated to incorporate indicators of compromise (IOCs) associated with Small Sieve and other malware strains attributed to MuddyWater. The emergence of Small Sieve underscores the ongoing evolution of malware techniques, characterized by advanced obfuscation methods and the exploitation of legitimate platforms such as Telegram for command and control purposes. Organizations are urged to maintain a heightened state of vigilance against threats posed by APT groups like MuddyWater and implement robust security measures to safeguard their systems.

Pre-Conditions:

- The commandClass object is accessible within the malware's code.
- The malware is running in an environment with a command line interface.
- A string containing "Platypus" is passed as an argument to the malware.
- A command line interface is available.

Post-Conditions:

- Increased risk of further attacks and malware infections.
- Data exfiltration to adversary-controlled servers.
- Modified Outlook data files.
- Potential for lateral movement within the network.
- New user account created.
- Network traffic logs showing communication with adversary-controlled IP addresses.
- Unusual system activity logs.
- Hidden files and folders containing malware code.
- Modified registry entries.
- Presence of obfuscated scripts and decryption tools.
- Altered system configuration files.
- Compromised system with persistent backdoor access.

MITRE Technique

ID: T1574.007

Name: Hijack execution flow: path interception by path environment variable

Description: Adversaries may execute their own malicious payloads by hijacking environment variables used to load libraries. The PATH environment variable contains a list of directories (User and System) that the OS searches sequentially through in search of the binary that was called from a script or the command line.

More info: <https://attack.mitre.org/techniques/T1574/007>

Attack Step a5

=====

Name: Masquerading: Match Legitimate Name or Location as used by the malware

Description: File naming conventions and registry entries are employed by MuddyWater actors to obfuscate malicious activities. Deceptive filenames mimicking legitimate Microsoft software components are utilized, incorporating variations such as "Microsift" instead of "Microsoft" and terms like "Outlook." Malicious executables may be disguised with names such as "MicrosiftOutlookData.exe." Persistence mechanisms are established through the exploitation of Windows registry entries. Keys are created under locations associated with legitimate Microsoft products or services, hindering detection by security tools due to the appearance of legitimacy. These tactics exploit human error, relying on heuristics and patterns employed by security analysts for threat identification. Deceptive filenames can mislead these systems into classifying malware as benign. Additionally, the sheer volume of files and registry entries within many organizations makes manual review impractical, facilitating the concealment of subtle manipulations. Mitigating these tactics involves implementing security awareness training to educate users about phishing attempts and the dangers of suspicious attachments or links. File integrity monitoring (FIM) systems should be deployed to track modifications to critical files and registry entries, triggering alerts for unauthorized changes. Advanced threat detection tools employing behavioral analysis, machine learning, and sandboxing techniques are crucial for identifying suspicious activity beyond basic signature-based detection. Furthermore, regular patching of operating systems, software, and firmware is essential to minimize vulnerabilities exploitable by attackers.

Pre-Conditions:

- Ability to modify files or system settings to reflect the chosen legitimate name or location.
- Requirements:
- Pre-Conditions:
- The malware utilizes legitimate names or locations in its operation.

Post-Conditions:

- System instability and performance degradation.
- Unusual network traffic patterns, including connections to known malicious IP addresses.
- Compromised system with persistent access for the attacker.
- Potential spread of malware to other systems on the network.
- Log files with suspicious entries related to command execution and data transfer.
- Hidden files and folders containing malware or stolen data.
- Presence of backdoors or remote access tools installed on the compromised system.
- New user accounts created with elevated privileges.
- Modified system registry entries indicating malicious activity.
- Data exfiltration to an external server controlled by the attacker.
- Altered timestamps on critical system files.

MITRE Technique

ID: T1036.005

Name: Masquerading: match legitimate resource name or location

Description: Adversaries may match or approximate the name or location of legitimate files, Registry keys, or other resources when naming/placing them. This is done for the sake of evading defenses and observation.

More info: <https://attack.mitre.org/techniques/T1036/005>

Milestone *m4*

Attack Step *a6*

=====

Name: Application Layer Protocol: Web Protocols as used by the malware

Description: This document presents a comprehensive analysis of MuddyWater, an Iranian state-sponsored advanced persistent threat (APT) group recognized for its sophisticated cyber espionage operations targeting governmental, diplomatic, and commercial entities globally. MuddyWater's Tactics, Techniques, and Procedures (TTPs) are detailed as follows: Malware Development: A diverse array of malware tools is utilized by MuddyWater, encompassing PowGoop, Small Sieve, Canopy/Starwhale, Mori, and POWERSTATS. These tools are engineered for functionalities such as backdoor access establishment, persistence maintenance, data exfiltration, and lateral movement within compromised networks. Exploitation Techniques: The group leverages known vulnerabilities to facilitate initial access to target systems. Recent instances include the exploitation of the Microsoft Netlogon elevation of privilege vulnerability (CVE-2020-1472) and the Microsoft Exchange memory corruption vulnerability (CVE-2020-0688). C2 Communication: MuddyWater employs diverse methods for communication with its command-and-control (C2) servers, including: Telegram API over HTTPS: This technique provides a relatively covert channel for data exfiltration and instruction reception. Domain Name System (DNS) tunneling: This method conceals malicious communication within legitimate DNS requests. Specific Malware Examples: Small Sieve: A Python backdoor characterized by its simplicity, utilizing the Telegram API for communication. It is designed for persistence maintenance, data exfiltration, and command execution. PowGoop: A modular malware framework capable of executing various tasks such as credential theft, lateral movement, and privilege escalation. It frequently employs obfuscation techniques to evade detection. Impact and Mitigation: MuddyWater's campaigns present a significant threat to organizations worldwide. Their sophisticated tactics and persistent nature can result in data breaches, intellectual property theft, and disruption of critical services. To mitigate the risks associated with MuddyWater, organizations are advised to implement robust security measures, including firewalls, intrusion detection systems (IDS), endpoint protection, and multi-factor authentication. Prompt patching of vulnerabilities is crucial, as is user education regarding phishing attacks. Continuous monitoring of network traffic for suspicious activity using security information and event management (SIEM) systems is essential for detecting and investigating potential intrusions.

Pre-Conditions:

- The malware must be executed on the victim machine.
- The adversary-controlled infrastructure is accessible via the internet.
- The malware is capable of establishing a network connection.
- A victim machine with an active internet connection.

Post-Conditions:

- System performance degradation.
- Altered file timestamps and permissions.
- Potential for further attacks and lateral movement within the network.
- Unusual process activity logs.
- Compromised system with persistent malware infection.
- Data remnants in temporary files or memory dumps.
- Malicious files in user directories (e.g., AppData/Roaming).

- Network connections to adversary-controlled IP addresses.
- Data exfiltration to adversary-controlled servers.
- Registry keys added for persistence.
- Modified system configurations.

MITRE Technique

ID: T1071.001

Name: Application layer protocol: web protocols

Description: Adversaries may communicate using application layer protocols associated with web traffic to avoid detection/network filtering by blending in with existing traffic. Commands to the remote system, and often the results of those commands, will be embedded within the protocol traffic between the client and server.

More info: <https://attack.mitre.org/techniques/T1071/001>

Attack Step a7

=====

Name: Data Encoding: Non-Standard Encoding as used by the malware

Description: Small Sieve, a Python-based backdoor attributed to the Iranian APT group MuddyWater, utilizes the Telegram Bot API for covert communication, rendering it less susceptible to detection by conventional network monitoring tools. The malware exhibits persistence through the utilization of an NSIS installer, ensuring its execution upon system reboots. Obfuscation techniques employed by Small Sieve include custom string modification within the malware code itself and a custom encoding scheme designated as "Hex Byte Shuffling." "Hex Byte Shuffling" involves the rearrangement of data bytes according to a predetermined algorithm prior to transmission. This process results in a scrambled byte sequence that lacks inherent meaning without the decryption key, which is shared between the backdoor and the command-and-control (C2) server. The rationale behind employing "Hex Byte Shuffling" encompasses evasion of security tools reliant on keyword analysis or known patterns, as well as the concealment of original commands or file names, thereby hindering the tracking of attacker activities.

Pre-Conditions:

- Access to the malware sample.
- The malware utilizing a non-standard encoding scheme is present in the system.
- A tool capable of analyzing and decoding non-standard encodings.

Post-Conditions:

- Potential for lateral movement within the network.
- Data exfiltration to MuddyWater C2 servers.
- Indicators of data exfiltration (e.g., unusual file transfers).
- Obfuscated PowerShell scripts and configuration files.
- Presence of malicious DLLs and executables.
- Modified registry entries for persistence.
- Compromised system with persistent backdoor access.
- Logs indicating suspicious activity, including file downloads, process executions, and network communication.
- Increased risk of further attacks and data breaches.
- Altered system configurations.

MITRE Technique

ID: T1001.001

Name: Data obfuscation: junk data

Description: Adversaries may add junk data to protocols used for command and control to make detection more difficult. By adding random or meaningless data to the protocols used for command and control, adversaries can prevent trivial methods for decoding, deciphering, or otherwise analyzing the traffic. Examples may include appending/prepending data with junk characters or writing junk characters between significant characters.

More info: <https://attack.mitre.org/techniques/T1001/001>